Phase 3 API Documentation

Contracts

Phase 3 adds tenant-isolated client observations and an explicit consent audit workflow under **`/api/v1/observations`**.

All protected routes require:

```
Authorization: Bearer <access_token>
Content-Type: application/json
```

The **`organisation_id`** is never accepted as tenant authority on its own. The server checks the user's active **`organisation_memberships`** row for role **`client`** before creation, listing, retrieval, grant, or withdrawal.

POST /api/v1/observations

• Purpose: create a private observation.

• Authentication: required.

• Role: active **`client`** membership.

• Body:

```
{
  "organisation_id": "bb22c7a6-4b1d-4fae-8f6a-25e2d6d7c890",
  "title": "Incorrect invoice calculation",
  "description": "The invoice total differed from the approved tax calculation.",
  "product_id": "7c5dd1d1-2dc8-4bd6-a6c2-6c9eb1c5b6d2",
  "category": "billing"
}
```

`title` is 1-255 characters; **`description`** is 10-10000 characters; **`category`** is at most 100 characters. **`product_id`** is optional and, when supplied, must identify an existing product.

• Success **`201`**:

```
{
  "success": true,
  "message": "Observation created",
  "data": {
    "id": "1f3e2d1c-9a88-4c7d-a123-abcdef123456",
    "title": "Incorrect invoice calculation",
    "description": "The invoice total differed from the approved tax calculation.",
    "product_id": "7c5dd1d1-2dc8-4bd6-a6c2-6c9eb1c5b6d2",
    "category": "billing",
    "created_by_user_id": "3c8e...",
    "organisation_id": "bb22c7a6-4b1d-4fae-8f6a-25e2d6d7c890",
    "status": "private",
    "consent_status": "not_granted",
    "consent_granted_at": null,
    "consent_granted_by_user_id": null,
    "consent_withdrawn_at": null,
    "consent_withdrawn_by_user_id": null,
    "created_at": "2026-10-30T14:00:00Z",
    "updated_at": "2026-10-30T14:00:00Z",
    "consent_events": []
  },
  "meta": {}
}
```

• Errors:

- **`401 AUTHENTICATION_REQUIRED`** — missing/invalid/expired token.

- **403 FORBIDDEN** — no active client role or organisation membership.

- **404 PRODUCT_NOT_FOUND** — optional product does not exist.

- **422 VALIDATION_ERROR** — invalid body fields or UUIDs.

GET /api/v1/observations

• Purpose: list observations from organisations where the user has an active **client** membership.

• Authentication: required.

• Role: active **client**.

• Query: optional **organisation_id**, **page** minimum 1, **page_size** 1-100.

• If **organisation_id** is supplied, membership for that organisation is required and results are restricted to it.

• Success **200** with an array of **ObservationOut** objects and pagination metadata.

• Errors: **401**, **403** for an unentitled supplied organisation, **422**.

Example:

```
GET /api/v1/observations?organisation_id=bb22c7a6-4b1d-4fae-8f6a-25e2d6d7c890&page=1&page_size=20
```

GET /api/v1/observations/{observation_id}

• Purpose: retrieve one observation.

• Authentication: required.

• Role: active **client** membership in the observation's organisation.

• Success **200** with one **ObservationOut** object.

• Errors:

- **401 AUTHENTICATION_REQUIRED**

- **403 FORBIDDEN** only when role checks fail globally.

- **404 OBSERVATION_NOT_FOUND** for unknown observations and cross-organisation observations.

- **422 VALIDATION_ERROR** for malformed observation UUID.

POST /api/v1/observations/{observation_id}/consent

• Purpose: intentionally grant consent to use the observation for shared learning.

• Authentication: required.

• Role: active **client** membership in the observation's organisation.

• Body is optional:

```
{"reason":"Approved for anonymised sharing"}
```

• Success **200**; returns consent status **granted**, grant actor/timestamp, and the consent audit event.

• Errors: **401**, **403**, **404 OBSERVATION_NOT_FOUND**, **409 CONSENT_ALREADY_GRANTED**, or **422**.

• Creating an observation never calls this endpoint automatically.

DELETE /api/v1/observations/{observation_id}/consent

• Purpose: withdraw previously granted consent.

• Authentication: required.

• Role: active **`client`** membership in the observation's organisation.

• Optional body:

```
{"reason":"Withdrawn by the organisation"}
```

• Success **`200`**; returns consent status **`withdrawn`**, withdrawal actor/timestamp, and the added audit event.

• Errors: **`401`**, **`403`**, **`404 OBSERVATION_NOT_FOUND`**, **`409 CONSENT_NOT_ACTIVE`**, or **`422`**.

Withdrawal behavior: the observation's current consent state is persisted as **`withdrawn`**. The audit history records both **`granted`** and **`withdrawn`** events. It prevents the contribution from qualifying as granted consent; no shared-learning endpoint exists in Phase 3, so no future consumer should use a withdrawn observation.

Database schema

New migration: **`alembic/versions/phase3_observations_and_consent.py`**.

observations

• UUID primary key.

• **`title`**, **`description`**, optional **`category`**, optional **`product_id`**.

• **`created_by_user_id`** and **`organisation_id`**.

• **`status`** default **`private`**; currently **`private`** or **`in_review`**.

• **`consent_status`** default **`not_granted`**; values **`not_granted`**, **`granted`**, **`withdrawn`**.

• Current grant and withdrawal actor/timestamp columns.

• Creation and update timestamps.

• Foreign keys to users, organisations, and optional products.

observation_consent_events

• UUID primary key.

• Observation, actor, and organisation foreign keys.

• **`action`**, timestamp, and optional reason.

• Append-only audit history. Application deletion cascades with the observation.

Files and tests

Created or modified:

• **`app/models/observation.py`**

• **`app/schemas/observations.py`**

• **`app/repositories/observation_repository.py`**

• **`app/services/observation_service.py`**

• **`app/api/v1/routers/observations.py`**

• **`app/models/__init__.py`**

- **app/api/v1/__init__.py**
- **alembic/versions/phase3_observations_and_consent.py**
- **tests/test_observations.py**

Tests cover creation, invalid input, cross-org creation/get/consent, client listing, persistence, explicit grant, repeated/unauthorized consent, and withdrawal.